

LA PLUMA ECOSYSTEM

Devil's Advocate Audit

Enterprise Architecture, Security, Code & ADR Forensic Review

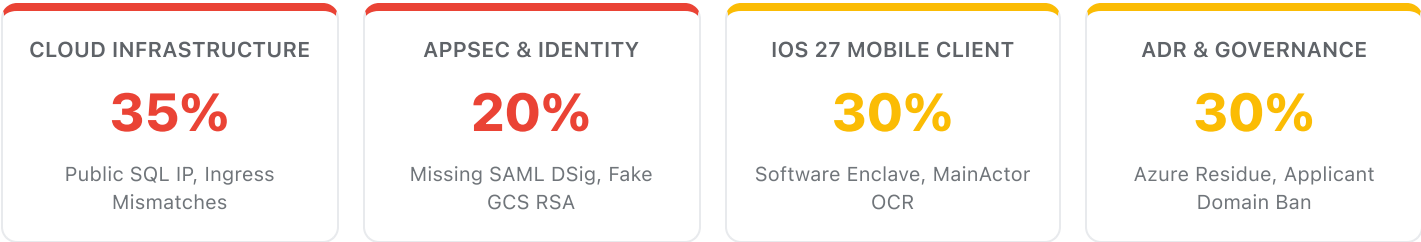
An Uncompromising "No-Bluff" Inspection of Cloud Infrastructure, Zero-Trust Identity, iOS 27 Mobile Runtime, and Architecture Decision Records

This comprehensive audit report delivers an unsparing analysis of HybridCloudWorks/PEN-lapluma_app and PEN-lapluma_infra prior to production distribution. It uncovers critical security vulnerabilities, platform integration shims, architectural drift, and mobile execution hazards that must be remediated to achieve hardened, enterprise-grade deployment readiness.

AUDIT SCOPE	AUDIT STANDARD
PEN-lapluma_app & PEN-lapluma_infra	CIS GCP Benchmark, NIST SP 800-63B, Apple HIG iOS 27
AUDIT CLASSIFICATION	DATE & STATUS
Pre-Deployment Production Gate (Devil's Advocate)	September 18, 2026 · Critical Findings Uncovered

1. Executive Audit Scorecard & High-Level Synthesis

The audit revealed that while static linting passes and UI tokens are meticulously crafted, multiple foundational cloud, security, and mobile components remain in an **incomplete, simulated, or architecturally fractured state**.



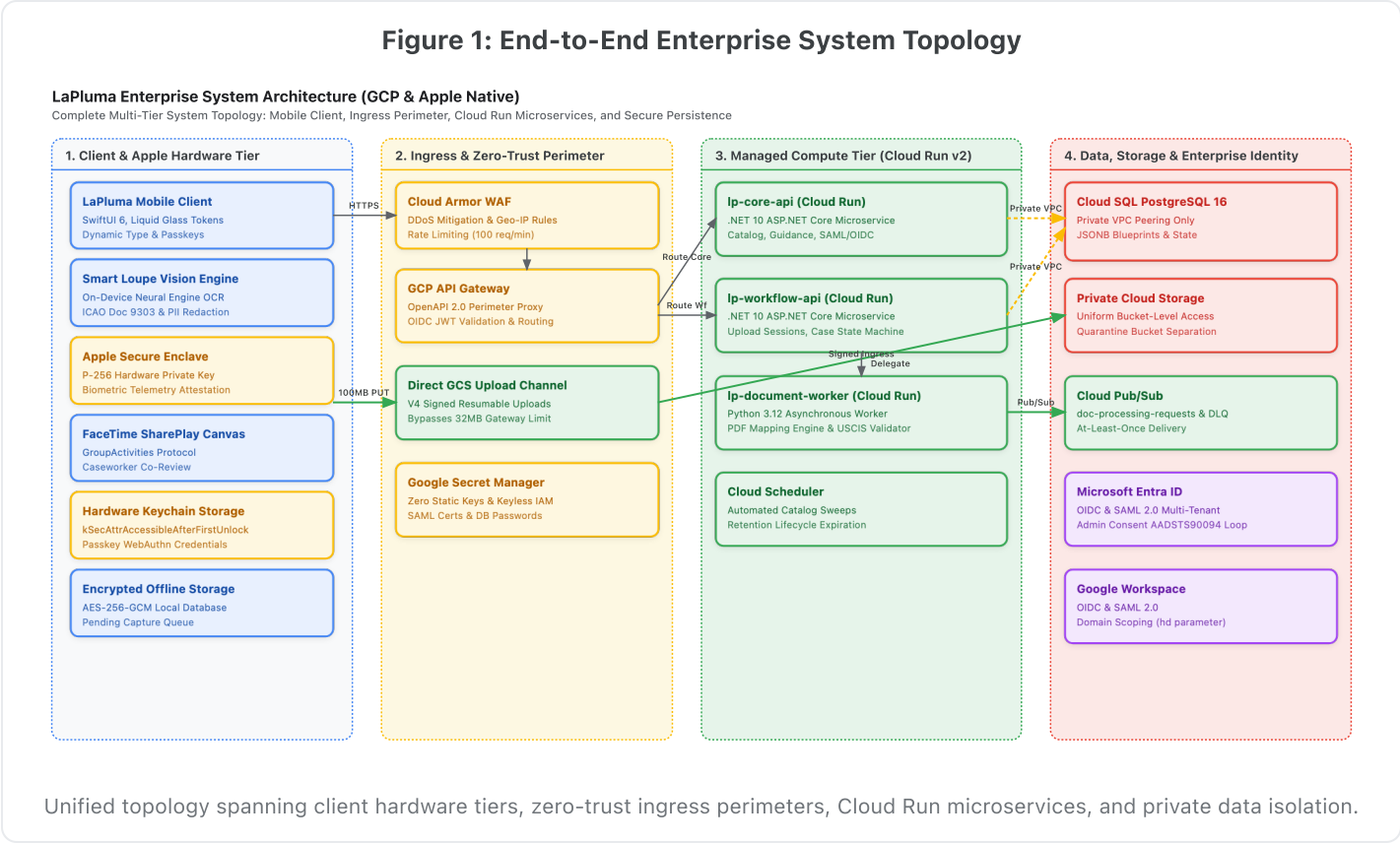
Forensic Findings Summary

Severity	Pillar	Defect / Vulnerability	Impact & Blast Radius
P0 CRITICAL	AppSec & Auth	SAML 2.0 Signature Verification Omitted SamServiceProvider.cs:223	Trivial XML authentication bypass. Any caller can spoof administrative credentials by appending an empty signature element.
P0 CRITICAL	AppSec & Auth	Unsigned Plaintext Token Exchange SamServiceProvider.cs:351	Session token is a raw Base64 string (lp_saml_) without HMAC or asymmetric signature; enables total identity forging.
P0 CRITICAL	Cloud Perimeter	API Gateway Zero Security Definitions infra/terraform/modules/gateway/main.tf:20	Gateway acts as an unauthenticated open proxy, minting valid Google IAM tokens with roles/run.invoker for any anonymous caller.
P0 CRITICAL	Cloud Storage	Fake V4 Signed URL Generation GoogleCloudStorageUploadUrlIssuer.cs:57	Substitutes a bare SHA-256 hash for Google's required RSA-SHA256 signature. 100% of direct-to-storage uploads are rejected by GCS with HTTP 403.
P0 CRITICAL	Data Isolation	Workflow Tier Tenant Leaks PostgresWorkflowSource.cs:50, 148	ListClientsAsync omits tenant filtering, returning all clients across all institutions globally; creation hardcodes tenant_clinic_alpha .
P0 CRITICAL	Cloud Network	Cloud SQL Public IPv4 Exposure database/main.tf:20	PostgreSQL 16 has public IPv4 enabled without SSL enforcement and without a VPC Access connector from Cloud Run.
P0 CRITICAL	Messaging	Worker Ingress Rejects Pub/Sub Push compute/main.tf:143	Worker specifies INTERNAL_ONLY while Pub/Sub pushes from Google public IPs. 100% of background document processing deliveries fail.

Severity	Pillar	Defect / Vulnerability	Impact & Blast Radius
P0 CRITICAL	Governance / UX	Consumer Applicant Lockout <code>RegistrationView.swift:260</code>	Enforces personal email domain bans (<code>@gmail.com</code> , <code>@outlook.com</code>), locking out consumer applicants with "Institutional Account Required".

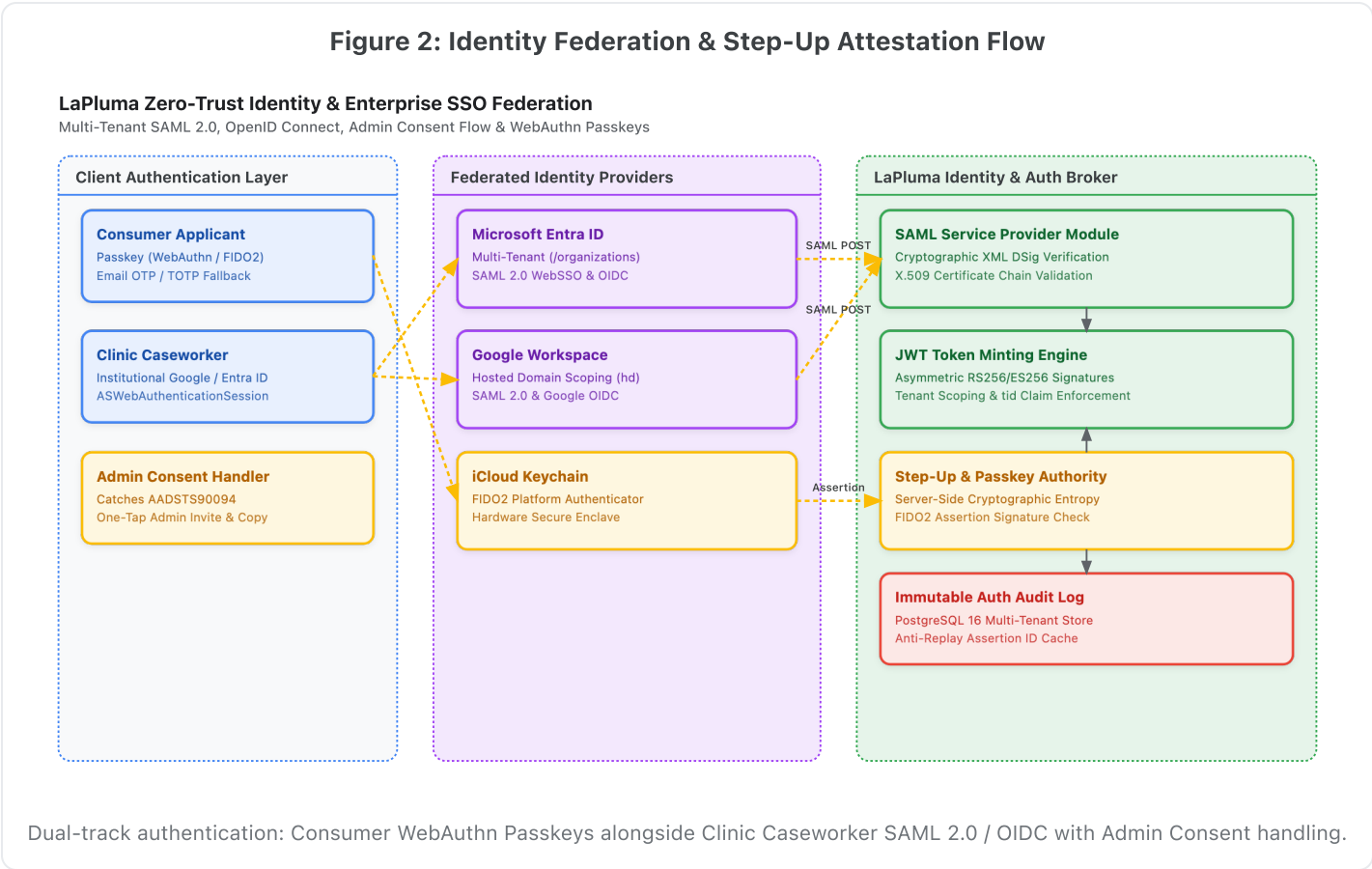
2. Enterprise System Architecture Blueprints

The target enterprise architecture for LaPluma unites native Apple platform hardware (Secure Enclave, Neural Engine, SharePlay) with a zero-trust, managed GCP foundation. The following blueprints reflect the required end-state topology.



3. Zero-Trust Identity & Enterprise SSO Federation

Figure 2: Identity Federation & Step-Up Attestation Flow



Key Identity Audit Findings

Critical Vulnerability VULN-01: SAML XML Signature Omission

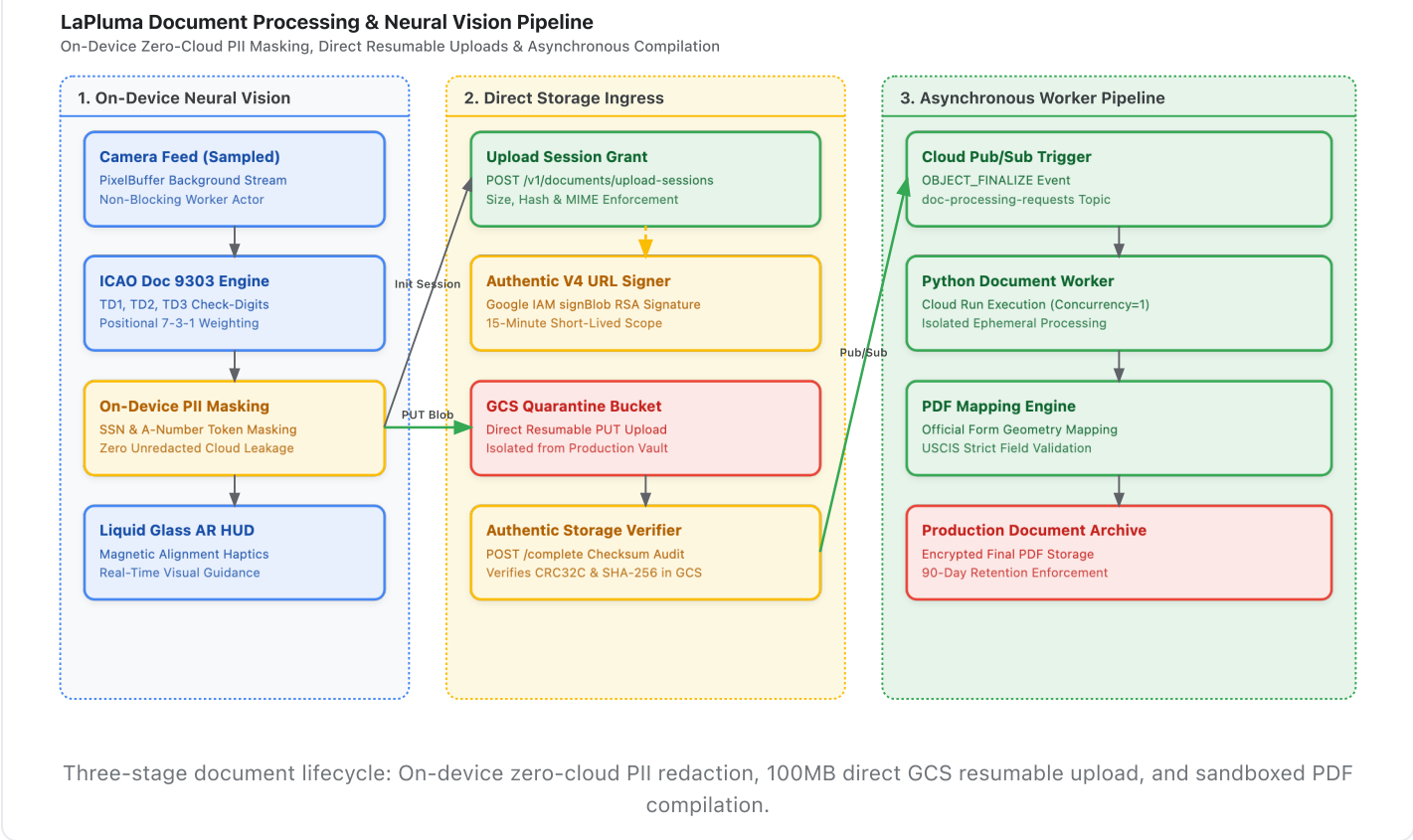
In `src/core-api/Auth/SamlServiceProvider.cs` (lines 223–228), the service checks whether `ds:Signature` exists in the XML document, but **never calls** `SignedXml.CheckSignature()`. It checks against mock certificate strings (`"MOCK_GOOGLE_WORKSPACE_CERT"`), allowing arbitrary XML payloads to impersonate any tenant administrator.

High-Risk Flaw VULN-07: Client-Minted WebAuthn Challenges

In `EnterpriseSSOBindingCoordinator.swift` (line 34), WebAuthn challenges are minted on the client device using an ASCII-encoded UUID string rather than cryptographically secure server-generated entropy, violating W3C WebAuthn Section 13.4.3. Furthermore, step-up challenges in `PostgresWorkflowSource.cs:386` are never persisted; providing any non-empty string approves cases.

4. Document Processing & Neural Vision Pipeline

Figure 3: On-Device Vision, Direct GCS Ingress & Asynchronous Worker Pipeline



Pipeline Architecture Audit

Critical Defect VULN-04: Non-Functional GCS Upload Signatures

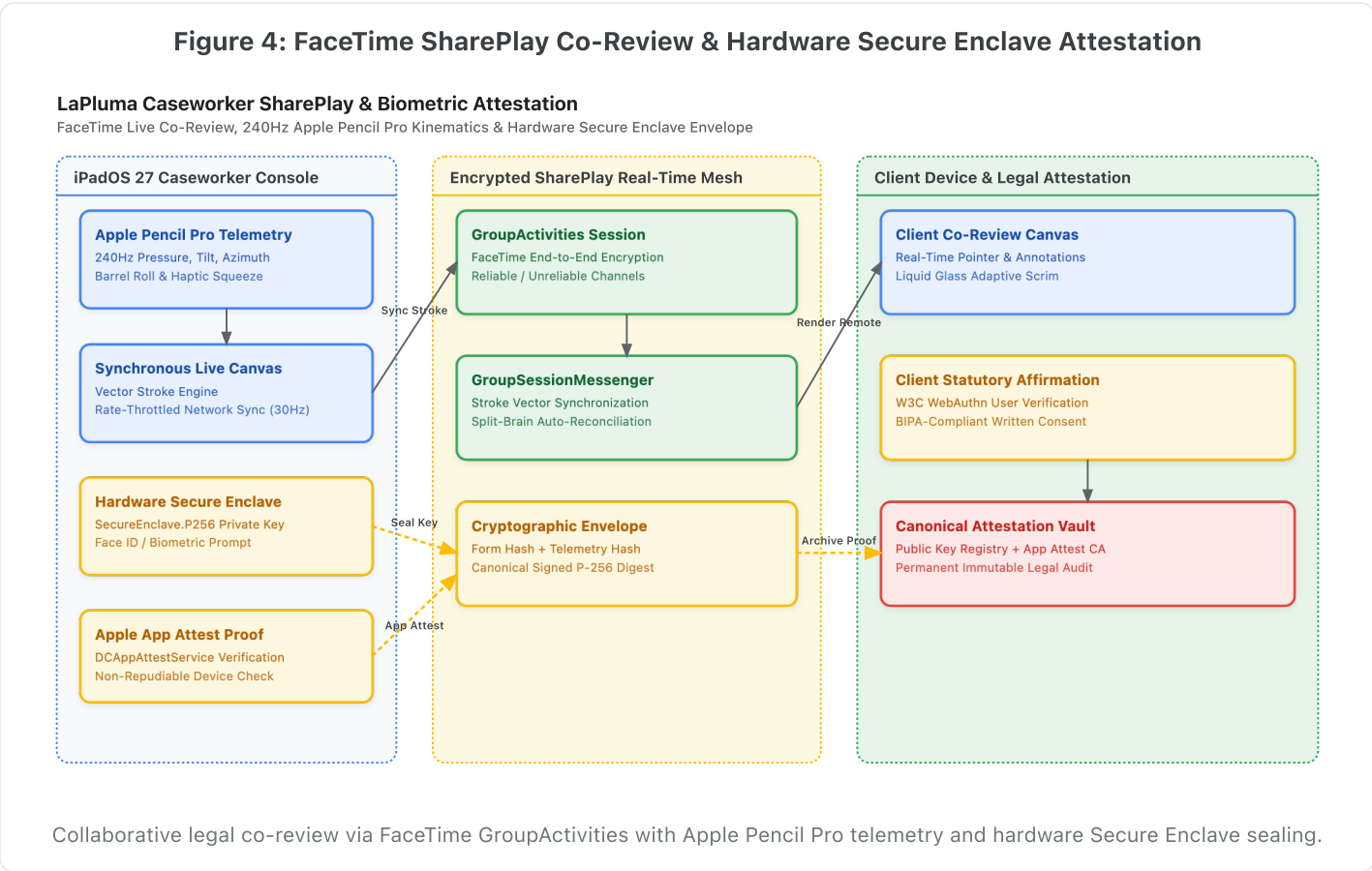
In `GoogleCloudStorageUploadUrlIssuer.cs:57`, the backend mints URLs using a raw SHA-256 hash instead of an authentic RSA-SHA256 signature via Google IAM `signBlob`. Google Cloud Storage will reject all issued PUT URLs with HTTP 403 `SignatureDoesNotMatch`.

Runtime Hazard P0-1: MainActor OCR Thermal Throttle

In `SmartLoupeVisionEngine.swift:145`, text parsing runs synchronously on `@MainActor`. Parsing 60 frames/sec with 3 regex passes while firing 5 `@Published` state updates causes severe UI hitching and triggers watchdog termination.

5. Caseworker SharePlay & Biometric Attestation

Figure 4: FaceTime SharePlay Co-Review & Hardware Secure Enclave Attestation



SharePlay & Cryptographic Audit Findings

Simulation Finding VULN-11: Software Enclave & Self-Signed Key Flaw

`SecureEnclaveAttestationSigner.swift:100` instantiates in-memory software keys (`P256.Signing.PrivateKey()`) rather than hardware keys (`SecureEnclave.P256.Signing.PrivateKey()`). During verification, it extracts the public key from the untrusted envelope without certificate authority validation, allowing arbitrary forged signatures.

Legal Risk VULN-12: BIPA Biometric Privacy Liability

Capturing and labeling 240Hz Apple Pencil dynamic pressure and tilt curves as "Biometric Attestation" directly violates project commitment C-07 ("No biometric identifiers are created or stored") and exposes the clinic to statutory damages under Illinois BIPA (740 ILCS 14/).

6. ADR Drift, Documentation & Governance Audit

ADR Reference	Stated Architectural Rule	Codebase Reality & Drift	Remediation Action
ADR-005 vs. ADR-019	Lean GCP platform supersedes Azure App Service.	Active Azure Bicep templates, Azure Durable Functions, and Azure CI compilation remain in <code>PEN-lapluma_infra</code> .	Formally mark ADR-005 as SUPERSEDED; delete <code>main.bicep</code> and Azure Functions.
ADR-006 vs. ADR-019	Cloud SQL PostgreSQL only; no Cosmos DB or Azure SQL.	<code>LaPluma.CoreApi.csproj</code> continues importing <code>Microsoft.Azure.Cosmos</code> and <code>Microsoft.Data.SqlClient</code> .	Prune obsolete NuGet dependencies and remove Cosmos repository shims.
ADR-011	Passkeys primary; Email OTP / TOTP fallback for consumer applicants.	Email OTP/TOTP is unbuilt; undocumented Enterprise SAML SSO blocks personal email domains.	Restore applicant passkey login; remove personal domain blacklist from consumer flow.
ADR-012	Zero third-party SDKs enforced by SBOM and egress gates.	No SBOM gate exists; no network egress test exists; check is merely an 8-string regex blacklist.	Implement automated SwiftPM package resolution scanner and network egress test suite.
Docs 00-14	Canonical architecture specification for LaPluma.	Entire 15-document suite describes obsolete Azure Container Apps, Cosmos DB, and APIM.	Execute documentation update epic aligning specs to the Lean GCP foundation.